Informe de Seguridad: Insufficient Workflow Validation

1. Título

Insufficient Workflow Validation — Omisión de validaciones en el proceso de compra

2. Descripción

Se identificó una falla de lógica de negocio en el flujo de compra de la aplicación. El proceso permite alcanzar la confirmación de una compra sin que se valide correctamente que el pago haya sido completado.

Durante las pruebas, la cuenta de usuario disponía de un saldo insuficiente para adquirir el producto *Lightweight l33t leather jacket*, cuyo precio era de 1337 unidades. A pesar de que el proceso de checkout rechazaba la operación por fondos insuficientes, fue posible acceder directamente al endpoint de confirmación de compra y completar el laboratorio.

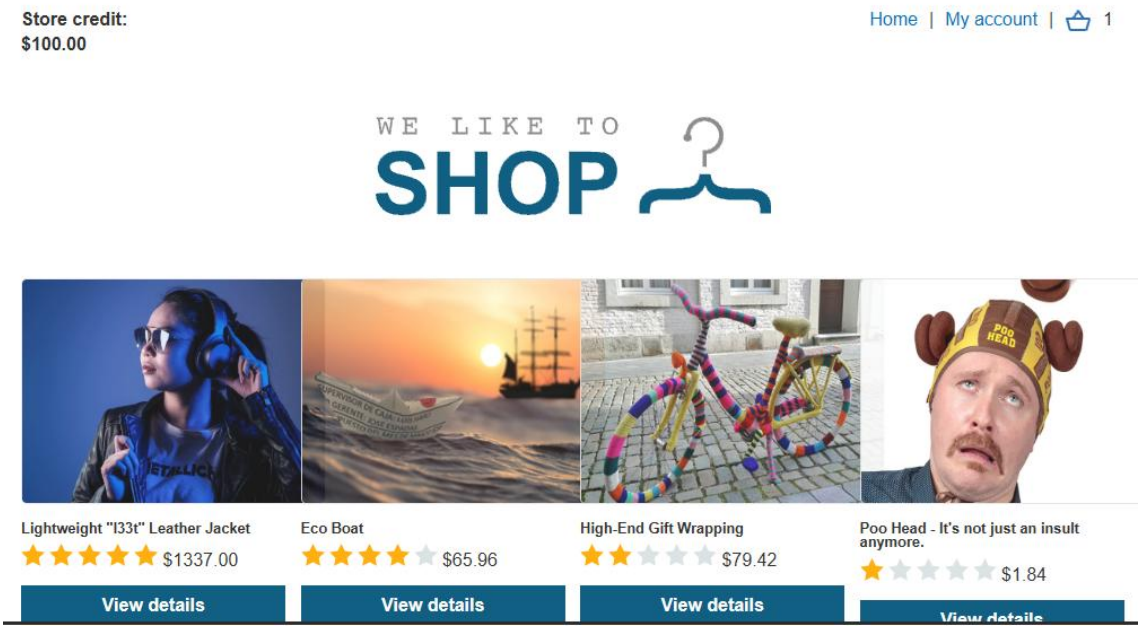
3. Entorno de prueba

- **Plataforma:** PortSwigger Web Security Academy.
- **Laboratorio:** Insufficient workflow validation.
- **Herramienta:** Burp Suite.
- **Producto objetivo:** Lightweight l33t leather jacket.
- **Precio del producto:** 1337 unidades.
- **Saldo inicial disponible:** 100 unidades.

4. Evidencia

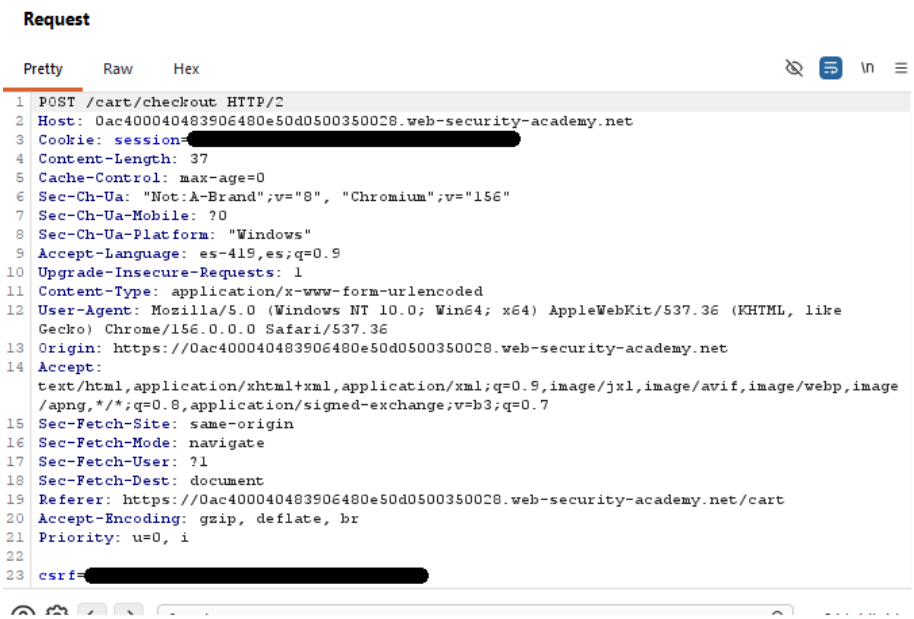
Evidencia 01 — Initial Page

Archivo:



Captura inicial de la aplicación utilizada para identificar el producto objetivo y comenzar las pruebas del proceso de compra.

Evidencia 02 — Checkout Request

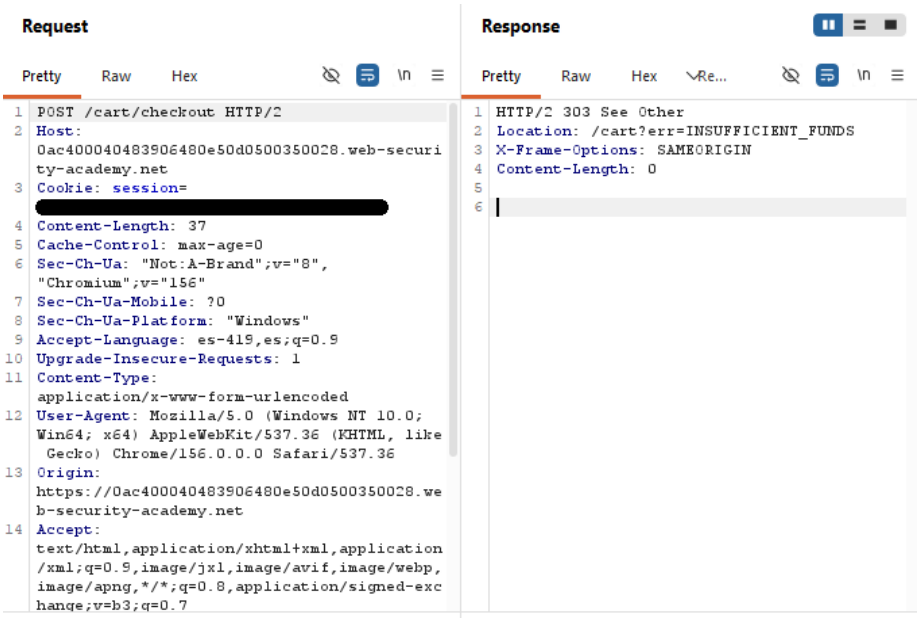


Archivo:

Solicitud HTTP `POST /cart/checkout` enviada al intentar completar la compra. La petición contiene el token CSRF correspondiente al formulario de checkout.

Evidencia 03 — Checkout Response

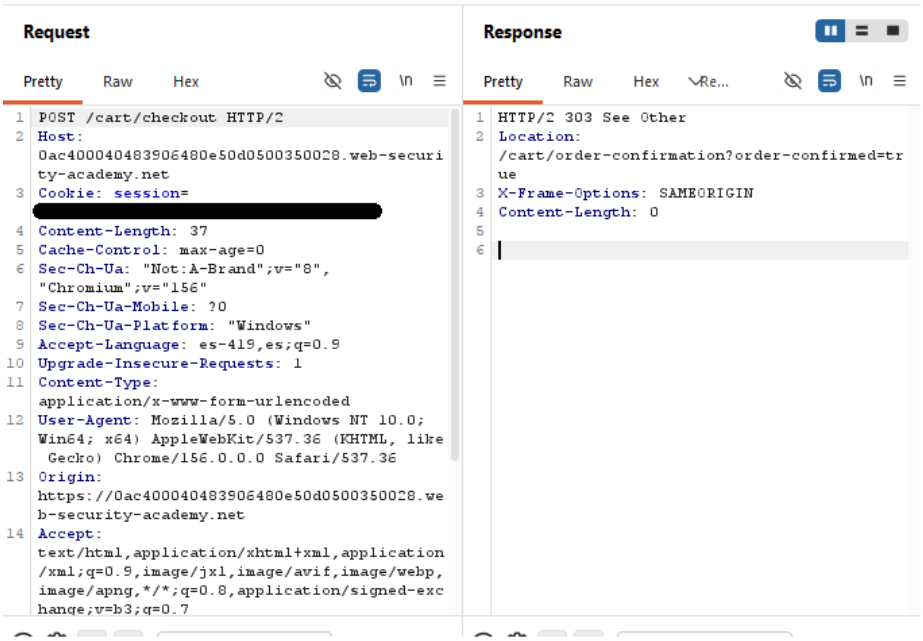
Archivo:



El servidor responde con `HTTP/2 303 See Other` y redirige a `/cart?err=INSUFFICIENT_FUNDS`, indicando que el saldo disponible no alcanza para completar la compra.

Evidencia 04 — Successful Checkout

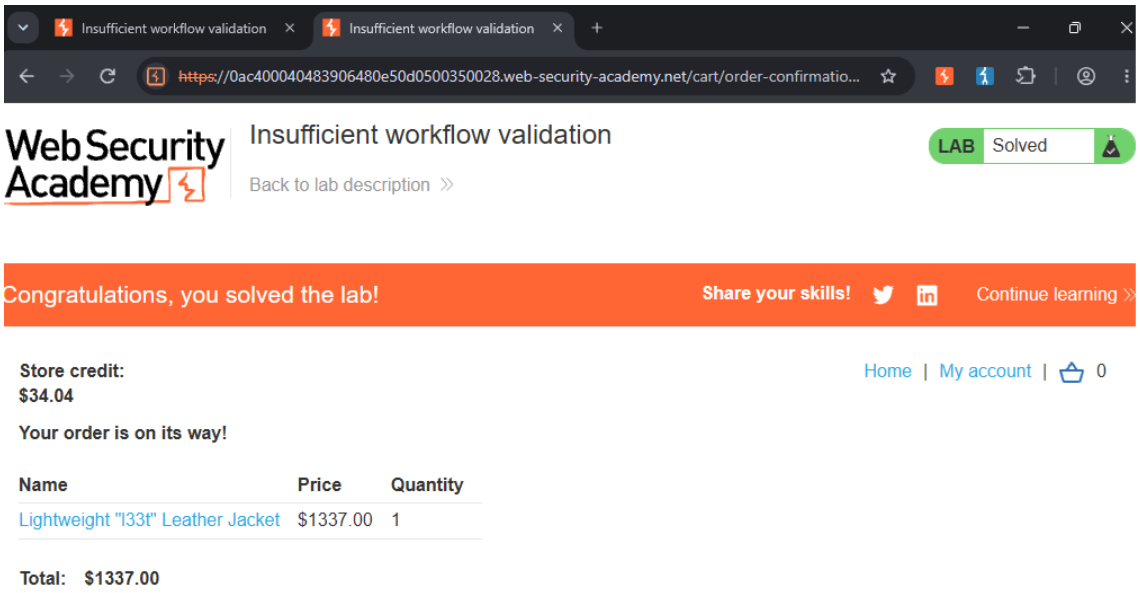
Archivo:



Captura del flujo de compra exitoso de un producto cuyo precio se encontraba dentro del saldo disponible. La respuesta redirige a `/cart/order-confirmation?order-confirmed=true`.

Evidencia 05 — Successful Purchase

Archivo:



Captura final que muestra la confirmación de la compra de la chaqueta y el estado de laboratorio resuelto. Se accedió directamente al endpoint `/cart/order-confirmation?order-confirmed=true` después del rechazo por fondos insuficientes.

5. Impacto

La falla permite eludir una validación del flujo de compra y alcanzar la confirmación de un pedido sin completar correctamente la comprobación del saldo.

- **Confidencialidad:** sin impacto directo demostrado.
- **Integridad:** impacto alto en el contexto del laboratorio, ya que puede registrarse una compra sin que se haya validado correctamente el pago.
- **Disponibilidad:** sin impacto directo demostrado.

En una aplicación real, una falla similar podría permitir la generación de pedidos no pagados y ocasionar pérdidas económicas, dependiendo de si el sistema de inventario, facturación y despacho confía en el estado de confirmación.

6. Causa raíz

La aplicación no valida adecuadamente el estado previo de la transacción al procesar el endpoint de confirmación. El servidor permite acceder a una etapa posterior del flujo sin comprobar de manera suficiente que el checkout haya finalizado con éxito y que el pago haya sido autorizado.

7. Remediación

- Validar en el servidor que el pedido haya completado correctamente todas las etapas requeridas antes de confirmarlo.
- Verificar el saldo y la autorización del pago en el momento de confirmar la transacción.

- Asociar cada confirmación con un pedido válido y con un estado de pago verificable.
- Implementar una máquina de estados del lado del servidor para impedir transiciones inválidas del proceso de compra.
- No confiar en que el usuario navegue por las páginas en el orden esperado.
- Registrar y monitorear intentos de confirmar pedidos que no hayan completado el checkout.

8. CVSS aproximado

CVSS: No asignado.

La puntuación requiere definir un escenario de explotación y un impacto técnico representativo de una aplicación real. El laboratorio demuestra una falla de lógica de negocio, pero no aporta información suficiente para asignar una puntuación CVSS universal sin establecer esos supuestos.

9. Prioridad

Alta en el contexto del laboratorio.

En una aplicación real, la prioridad dependería de si la confirmación permite efectivamente generar pedidos, liberar productos o activar un despacho sin un pago válido. La evaluación debe considerar el impacto económico y los controles posteriores del sistema.